LEXIGRID

Evidence-Grounded AI Risk Assessment

Version 5.54.15 | Reviewed 2026-11-11

Shahryar Jahangir, Aniza Inc.

Procedures, examples, verification and operational limits. Complete commissioning on your deployment before serving customer traffic. Sample values are fictional; original keys and data must be preserved.

Contents

Evidence-grounded AI assessment and workspace **3**

- Purpose and authority . . . 3
- Administrator setup . . . 3
- Prepare evidence . . . 3
- Run and review . . . 3
- Evidence Workspace procedure . . . 3
- Provenance and legacy proposals . . . 4
- Failure handling and verification . . . 4
- Review and explicitly apply an AI assessment . . . 4

Risk assessment methodologies and reports **5**

- Perform a single-risk or batch assessment . . . 5
- Available methodology profiles . . . 7
- FAIR quantitative assumptions and output . . . 7
- Export contents and interpretation . . . 8
- Official references . . . 8
- Deployment and runtime behavior . . . 8

Automatic risk-to-governance matching **8**

- Open a risk to scan . . . 8
- Coverage and interpretation . . . 9
- Model configuration and data . . . 9
- API . . . 9

Evidence-grounded AI assessment and workspace

Purpose and authority

Use model recommendations to support a human risk decision. The authoritative likelihood, impact and score do not change automatically. A saved proposal is not an approval or a proof that controls operate effectively. Model confidence is not a calibrated probability.

Administrator setup

1. Choose the approved provider/model and data handling policy. Local Ollama is the default path; model/runtime installation and availability must be verified separately.

2. Keep LEXIGRID_AI_AIRGAPPED=1 and LEXIGRID_AI_ALLOW_CLOUD=0 for the local-only configuration. Configure the approved local host list and endpoint.

3. For explicit cloud operation, obtain the required authorization and configure the provider key through approved storage. Do not place secrets in the browser or CLI arguments.

4. Use AI status/providers/models/test as appropriate. Models/test can contact the configured endpoint; they are not automatically offline-safe.

5. Restart after deployment environment changes and verify a designated test risk. A connection response is not evidence of a useful assessment.

Prepare evidence

Create a clear cause/event/consequence risk. Link relevant controls, record real control tests and findings, attach appropriate evidence and document treatments/assessments. Evidence filenames/hashes are metadata; they do not mean the model has read every attachment. Review exactly what the Evidence Workspace sends before relying on an answer.

Run and review

1. Open an active risk through Manage. An authorized role may trigger one automatic evaluation per risk/version/browser session; manual Evaluate with AI supports reassessment.

2. Review current and proposed likelihood/impact/score, rationale, actions, treatment and identified gaps.

3. Inspect supporting control/test/finding references. Unsupported/invented references and invalid scores must be rejected by response validation.

4. Choose Keep current assessment or Apply AI assessment. Applying requires explicit confirmation and preserves version/provenance/approval checks; see the detailed procedure below.

5. If the provider is unavailable or its schema is invalid, keep using ordinary risk functions. Do not remove a risk or change its score merely to make AI succeed.

Evidence Workspace procedure

Inspect linked controls and test outcomes, findings, evidence metadata, prior assessments/treatments and missing-information questions. Link a control only when it actually addresses the risk. Upload evidence against the intended control, then verify the server hash and an authenticated download. Owner labels and an implemented status do not establish effectiveness without tests.

Answer missing-information questions with actual facts and references. User answers are inputs, not independent proof. Reassess after relevant context changes and compare the exact evaluated input rather than assuming a prior proposal used the new evidence.

Provenance and legacy proposals

Generated proposals record an evaluated-input digest and saved output digest. The risk panel marks provenance verified only when the stored payload matches the assessment event. Generic Enterprise IRM creates/edits cannot fabricate AI payloads. Legacy proposals without matching evidence remain available but are marked unverified and are not presented as authenticated model scoring/rationale.

History is limited after selecting the target risk, rather than globally allowing unrelated proposals to hide that risk's history. A provenance label proves the recorded origin of that proposal, not the truth of a recommendation.

Failure handling and verification

The adapter accepts supported fenced JSON/numeric strings and retries a malformed schema once under its documented contract. Boolean/out-of-range scores and unsupported evidence references remain invalid. Capture bounded error class, model, timestamp and risk identifier; do not log sensitive raw model output.

Verification uses designated risks: confirm no official score change after assessment, role/tenant denials, accurate context references, readable unverified legacy status and continued ordinary risk editing during provider failure. Qualify model quality, egress restrictions and customer policies on the target deployment.

Review and explicitly apply an AI assessment

AI generation creates a proposal and leaves the official risk unchanged. The panel shows current likelihood/impact/score, the evidence-checked proposal, confidence, linked-control/test counts, information gaps and limitations. The original model estimate and narrative remain available when evidence checks change the proposal; they are not the values adopted by the Apply action.

Evidence checks for the current rating

A missing process, planned control, filename/hash, user attestation or proposed treatment does not establish lower current exposure. For example, a risk at likelihood 5 and impact 5 remains at score 25 when a model suggests 4 and 4 but only a planned control and no test results support it. The panel records low confidence and explains the retained dimensions. A raw model can still produce incorrect numbers or prose; these checks are conservative product rules, not a calibrated prediction or compliance certification.

Reductions are checked separately for likelihood and impact. Each reduced dimension needs a model reason and cited supporting records. Current control-effectiveness support requires an implemented linked control, its latest passing test within 90 days, references to both, and no unresolved high/critical finding for that control. Alternatively, a recent human-recorded inherent/residual assessment made after the last risk edit can support a correction no lower than that assessment's dimension. Future target assessments and prior AI-adopted assessments do not independently corroborate a reduction. Unusable optional model justifications are discarded; invented top-level evidence references and invalid required scores remain rejected. The 90-day window is the current application evidence-check policy, not an assertion about a standard's mandated testing interval.

Keep the current assessment

1. Open Risks > Manage and review the proposed assessment and its evidence checks. Scroll inside the dialog to see the choice controls.

2. Optionally enter a review note.

3. Select **Keep current assessment**.

4. The proposal is recorded as rejected/declined. The official likelihood, impact and risk version remain unchanged, and no new residual assessment is created. The decision and actual user are audited.

Apply the reviewed AI assessment

1. Review the checked likelihood/impact/score, confidence, rationale, proposed treatment/actions and gaps.

2. Select **Apply AI assessment**. The interface displays the exact current-to-proposed score comparison.

3. Select **Confirm and update risk**, or **Cancel** to return without applying.

4. On confirmation, the server uses the saved, provenance-bound checked dimensions. It updates the official likelihood/impact, increments the risk version, creates a residual assessment with its rationale and actual human assessor, and records the proposal as accepted. The original proposal author is retained.

5. The register is refreshed and reports/dashboard reads use the new official rating. Existing opted-in risk-change notifications follow the normal transaction-safe queue. Proposed treatments/actions remain recommendations; applying does not mark them completed or create invented due dates. Risk title, description, owner, category and lifecycle status are retained.

If evidence checks retained the current score, applying can legitimately preserve the same numeric score while saving the reviewed assessment and decision. For example, both scores can be 25 because no effective mitigation is demonstrated. A supported 4-by-4 proposal applied to a 5-by-5 risk changes the official score to 16.

Permissions, approvals and stale proposals

Only users with the existing risk-edit permissions (platform/tenant administrator, risk manager or risk editor) can decide. Apply is an explicit human risk-edit action; it is not automatic model approval. If a formal workflow has already been started for this proposal, its latest run must provide an unconsumed approval for this exact record version/content and the accepted target state. An unbound, pending, rejected or stale approval cannot be bypassed. Generic Enterprise IRM Review opens the risk panel; generic transitions cannot manufacture an accepted AI state without adopting through the checked decision path.

A changed risk version, changed linked evidence/answers, closed risk, altered payload, invalid signature or expired support blocks applying. Evaluate again and review the new proposal. Historical proposals produced before the current evidence policy are retained but require reassessment before adoption. Keep can decline such a proposal without overwriting the current risk. Duplicate or competing decisions do not create a second assessment or overwrite a newer risk. Request references identify failures; a failed transaction leaves the risk, assessment history, decision and queued notifications unchanged.

Provenance binds the stored proposal to its recorded digest and, when audit signing is configured, its valid audit signature. It authenticates the saved record, not the truth of the model's judgment. PostgreSQL timestamps are normalized to UTC for verification of existing UTC-signed audit entries; no audit history or stored signatures are rewritten.

Risk assessment methodologies and reports

Author: Shahryar Jahangir, Aniza Inc.

Perform a single-risk or batch assessment

1. Open **Risk Assessment** from the navigation menu. Select an assessment methodology. Read its scope notice and official reference link.

2. Select one or more defined risks, with no fixed risk-count ceiling. Previous/Next pages retain the selection; Clear selection resets it. Risks remain within the current workspace.

3. Expand each selected risk's scenario inputs. Provide scope, relevant assets, threat scenarios, vulnerabilities, organization acceptance criteria and sector details. Treat these entries as assertions; link control tests and other records from the risk to supply supporting evidence.

4. For FAIR, optionally provide every financial factor range and its estimation basis as described below. Leave all financial inputs blank to receive a missing-data analysis without invented monetary estimates.

5. Select **Assess selected risks**. Keep the page open while each selected risk is processed by the configured AI provider. The selected methodology is different from the language model: provider/model and air-gapped/cloud controls remain administrator settings.

6. Review the saved report's status, per-risk findings, confidence, evidence checks, gaps and proposed treatment. Failed or stale items are explicitly marked; retry those risks after resolving the cause. Successful risks remain available in partial reports.

7. Download JSON, PDF or CSV from the report. Saved reports preserves the assessment-time snapshot; later edits do not rewrite it. The most recent 100 reports are listed.

8. To accept a successful risk's proposed ordinal rating, select **Review rating: Keep or Apply**. This opens the shared review panel without running a different assessment. It identifies the methodology and offers Keep current assessment or Apply AI assessment. Apply requires explicit confirmation and rechecks current risk/evidence versions, provenance, permissions and any bound approval workflow. Financial estimates and proposed treatments remain advisory. Historical reports continue to show their original official-rating snapshot after adoption.

Risk administrators, managers and editors may run assessments. Other authenticated workspace members may read and export saved reports. Each creation, proposal, adoption decision and export is audited; errors retain request references. No rating changes merely because a report was generated or downloaded.

Available methodology profiles

Methodology	Analysis performed	Scope and limits
NIST SP 800-30 Rev. 1	Threat sources/events, vulnerabilities and predisposing conditions, event and adverse-impact likelihood, impacts, uncertainty and monitoring	Structured qualitative profile using LexiGrid's disclosed five-point scale. NIST does not prescribe one universal ordinal product matrix.
FAIR / Open FAIR	Loss scenarios, threat-event frequency, vulnerability probability, primary/secondary loss and data quality, plus reproducible range calculation	User-supplied quantitative factors are required for money estimates. This is a LexiGrid implementation of FAIR concepts, not a certified Open FAIR tool.
ISO/IEC 27005:2022	Context/criteria, asset-threat-vulnerability scenarios, identification, analysis, evaluation, treatment, communication and review	Organization criteria must be supplied. No licensed standard text or conformity assertion is included.
HHS Security Risk Assessment	ePHI assets/vendors, administrative, physical and technical safeguards, threats, impacts and remediation	HHS SRA-informed analysis; not the official SRA application, exhaustive questionnaire or HIPAA compliance determination.
FFIEC CAT (legacy)	Inherent-risk considerations and the five cybersecurity maturity domains, with evidence gaps	FFIEC retired CAT on August 31, 2025. A selected-risk report cannot determine institution-wide CAT maturity.
CISA Infrastructure Survey / resilience screening	Facility threat scenarios, physical protections, security management, dependencies, cascading impacts, recovery and missing observations	IST-informed desk screening. It does not conduct a site inspection, official CISA survey, peer comparison or protective/resilience index.
CISA Cybersecurity Performance Goals	IT/OT scope, governance/identification, protection, detection, response, recovery and prioritized outcomes	CPG-informed analysis rather than an official CSET module or complete CPG checklist. Validate proposed mappings against the current publication.

Every profile requires its own analysis sections. The server rejects incomplete structured responses after one retry, rather than presenting generic text as a successful methodology assessment. AI statements and mappings require review against the cited records; file metadata and assertions are not verified effectiveness. Unsupported reductions in current likelihood or impact are held at the existing rating. The unadjusted model estimate is separately retained.

FAIR quantitative assumptions and output

For each risk, enter a three-letter currency code and low / most likely / high values for: threat events per year; vulnerability (probability a threat event becomes a loss, from zero to one); primary loss per event; probability of secondary loss (zero to one); and secondary loss when it occurs. Include the data sources, observation period and assumptions in the basis field. All ranges must be ordered and nonnegative. Zero is a valid value. Partial ranges are rejected. Different risks may use different assumptions or currencies; the product does not add them into an unsupported portfolio total.

The server computes annualized expected loss as annual threat-event frequency multiplied by vulnerability multiplied by primary loss plus probability-weighted secondary loss. Independent triangular distributions are used for low/most-likely/high inputs, with 10,000 seeded draws; constant ranges remain constant. The report preserves the inputs, deterministic seed, formula, analytic mean and P10/P50/P90 uncertainty values. These percentiles describe uncertainty in annualized expected loss, not annual aggregate loss percentiles or value-at-risk. Independence and stable annual rates are assumptions to validate; AI does not supply missing financial factors. The five-point ordinal rating is reported separately and is never converted into money.

Export contents and interpretation

JSON preserves the report envelope, author, method/version, provider/model, scenario inputs, per-risk source snapshots, evidence references, input/output hashes, analysis, checked ratings, gaps and quantitative assumptions/results. CSV uses a lossless two-column field/value layout with indexed paths for nested risks and factors; spreadsheet formula prefixes are escaped. PDF presents readable methodology findings, ratings, scenario inputs, evidence checks, gaps, financial factors/results and provenance hashes across numbered pages; JSON retains the complete machine-readable source snapshots. Supplied markup is escaped. All three formats are downloadable from the same saved report and record an export audit event. Failed/stale item statuses and missing-data notices remain in exports.

Official references

- NIST SP 800-30 Rev. 1 (2012): https://csrc.nist.gov/pubs/sp/800/30/r1/final

- The Open Group Open FAIR risk-analysis publication: https://pubs.opengroup.org/security/o-ra/

- ISO/IEC 27005:2022 publication description: https://www.iso.org/standard/80585.html

- HHS/ONC SRA tool and its limitations: https://healthit.gov/privacy-security/security-risk-assessment-tool/

- FFIEC CAT sunset notice: https://www.ffiec.gov/news/press-releases/2024/an-09-29

- CISA Infrastructure Survey Tool: https://www.cisa.gov/resources-tools/services/infrastructure-survey-tool-ist

- CISA Cross-Sector Cybersecurity Performance Goals:
https://www.cisa.gov/cross-sector-cybersecurity-performance-goals

References checked November 6, 2026. These profiles are advisory adaptations, not official agency applications, examinations, certifications or licensed reproductions.

Deployment and runtime behavior

Assessment calls are synchronous and process the selected risks sequentially without a fixed risk-count ceiling, with a 90-second provider read timeout and at most one schema-repair retry per risk. Large local-model batches can therefore take longer in proportion to the number of selected risks. Operators must configure the TLS reverse proxy/request timeout for the selected batch size (allow up to approximately three minutes per risk for two provider timeouts), or use smaller batches. If the connection times out, check Saved reports before retrying: a completed server-side report may already exist. There is no background-job progress or cancellation API in this profile. Source context is bounded to linked-record limits; a report is not an exhaustive assessment of all organizational records.

Automatic risk-to-governance matching

Author: Shahryar Jahangir, Aniza Inc.

Open a risk to scan

Open **Risks -> Manage**. For an authorized risk editor, the **Applicable policies, controls, frameworks and requirements** section automatically checks the current workspace catalogue and generates AI applicability matches. It shows progress, then matched record identities, lifecycle states, confidence, risk-specific reasons and exact supporting quotations. Use **View matched record** to read the current full record and **Back to risk** to return. Frameworks containing a matched requirement are explicitly identified as a derived association; that association does not establish that every provision of the framework applies.

Matching is saved per risk and catalogue snapshot. Opening the same risk reuses current saved matches. Changes to the risk, policies, controls, frameworks or requirements invalidate the snapshot and the next opening rescans. **Rescan**

applicable records requests a fresh model result. Read-only users can view current saved matches; they cannot start model work. A failed or stale scan displays its request reference and can be retried. It does not replace a valid historical scan with invented matches.

Coverage and interpretation

The application text-scans every policy, control, framework and requirement in the authenticated workspace, including all passages of long policy bodies. It ranks candidates using risk terms and related terminology, then asks the configured AI to evaluate a shortlist of up to six records per type using relevant excerpts. The screen reports both full catalogue counts and AI-reviewed counts. Additional applicable records may exist outside the shortlist; this is assisted discovery and must not be treated as an exhaustive regulatory mapping. Empty matches mean no applicable item was identified among the reviewed candidates, not that no obligation exists.

The AI must cite an exact source excerpt and an identifier belonging to a supplied current-workspace candidate. Unsupported references, invented quotations, invalid confidence values and duplicate references are rejected. A bare ID is normalized only when it uniquely identifies one supplied candidate. Record content and risk descriptions are untrusted data, never executable instructions. Parent-framework associations are verified against the requirement's stored framework identity.

Matches are automatically saved applicability associations. They do not change the risk's likelihood, impact, score, ownership or lifecycle. They do not create verified control-evidence links or prove that a draft policy is approved, a planned control works, or a requirement has been satisfied. Use the existing evidence workspace and control tests for verified evidence. Official AI ratings retain the explicit Keep/Apply review process.

Model configuration and data

Matching uses the existing configured AI provider and model. Local Ollama remains the default for air-gapped installations; matching does not enable cloud access or bypass provider configuration. Cloud model use requires the existing explicit administrator opt-in. Automatic matching sends risk text and selected governance excerpts to that configured provider. If the model is unavailable, the rest of the risk screen remains usable and the matching section shows an actionable error.

Scan results identify the provider, model, snapshot, scanned/reviewed counts and limitations. Successful scans are transactionally audited with the reviewer, risk identity, catalogue digest and matched references. Failures and HTTP transactions are logged with request references without copying source policy bodies, prompts, secrets or raw provider responses into logs.

API

All routes require an authenticated current-workspace session or bearer token. Substitute actual IDs.

- `POST /api/ai/risks/{risk_id}/governance-matches` creates or reuses a current scan under the existing risk-edit roles. Add `?force=true` to regenerate.

- `GET /api/ai/risks/{risk_id}/governance-matches` reads current saved matches, or reports `not_scanned` / `stale`.

- `GET /api/requirements?limit=100&offset=0` lists requirements across the workspace, including framework name and revision. The result has `total`, `limit`, `offset` and `items`. Follow pages to read all records; page size may be 1 through 500.

- `GET /api/requirements?q=access&framework_id={framework_id}` searches reference, requirement text or framework name, with an optional framework filter. Search treats percent and underscore literally.

- `GET /api/requirements/{requirement_id}` retrieves a complete requirement and framework identity.

- `GET /api/frameworks/{framework_id}/requirements` retains the existing framework-scoped listing.

- `POST /api/frameworks/{framework_id}/requirements` adds a requirement using `{"reference":"AC-1","text":"Review privileged account access quarterly."}` under existing governance-edit permissions.

- `PATCH /api/frameworks/{framework_id}/requirements/{requirement_id}` edits a requirement with its current content version, reference and text.

Cross-workspace risk, requirement or framework IDs return not found. The interactive API schema remains available at `/docs` on the installation.